

◆ What is Intruder in Burp Suite?

- **Intruder** is an automated attack tool inside Burp Suite.
- It allows you to send **many requests quickly with different inputs (payloads)**.
- Useful for:
 - Brute-force attacks (e.g., password guessing)
 - Fuzzing (finding hidden parameters/values)
 - Testing for injections (SQLi, XSS, etc.)

◆ How Intruder Works

1. Capture a request in **Proxy** or **HTTP history**.
2. Send it to **Intruder** (Right-click → *Send to Intruder*).
3. Select **positions** (where you want to insert payloads, e.g., username, password, cookies).
4. Choose an **attack type** (Sniper, Battering Ram, Pitchfork, Cluster Bomb).
5. Add **payloads** (wordlist, numbers, custom text, fuzzing strings).
6. Start the attack → Intruder will send multiple requests automatically.
7. Analyze **responses** to find vulnerabilities or valid credentials.

◆ Attack Types in Intruder

1. **Sniper** → Tests one position at a time with payloads.
(Best for single parameter testing).
2. **Battering Ram** → Inserts the same payload in multiple positions.
(Good for when same input must be repeated).
3. **Pitchfork** → Uses multiple payload sets in parallel.
(Good for testing username+password lists).
4. **Cluster Bomb** → Tests all combinations of payloads.
(Best for brute force or fuzzing multiple parameters).

◆ Example 1: Password Brute Force

Suppose you captured this request:

POST /login HTTP/1.1

Host: target.com

username=admin&password=\$1234\$

- Select **password** as payload position.
- Add a password wordlist (like rockyou.txt).

- Attack type → **Sniper**.
- Intruder will try all passwords for admin.
- Response with **200 OK** or different length = valid login found.

◆ **Example 2: Fuzzing Hidden Parameters**

Captured request:

GET /profile?user=\$test\$ HTTP/1.1

Host: target.com

- Select user as payload position.
- Add fuzzing payloads: admin, root, guest, 123, etc.
- Attack type → **Sniper**.
- If admin gives different response (like showing admin profile) → vulnerability found.

◆ **Why Intruder is Powerful**

- ✓ Automates **repetitive testing**.
- ✓ Finds weak passwords, hidden inputs, or injection points.
- ✓ Saves time vs manually sending requests in Repeater.